DRAFT VERSION

Administrative Control Plan

Training, Job Rotation, Mandatory Vacation & Disaster Recovery Plan

Sample-Ama Uris

Context

In this activity, you will create a plan for an administrative control. Use any company you have worked for or would want to work for.

Company

X

• Explain the cybersecurity onboarding training that employees will take.
• Explain how often employees must complete additional cybersecurity training. Justify your response.
• Describe how you would inform employees about new cyberthreats.

Executive Summary

- *Training*
  - *Purpose and Scope*
  - *control Relationship to Organizational Security Goals.*
- *Job Rotation*

    - *Purpose and Scope: Mitigating Insider Risk*
    - *Alignment with Segregation of Duties (SoD) Policies*
- *Mandatory Vacation*
    - *Purpose and Scope: Fraud Detection and Operational Continuity*
    - *Alignment with Internal Audit Requirements*
- *Disaster Recovery*
    - *Purpose and Scope: Operational Resilience*
    - *Alignment with Business Continuity Objectives*

Sample-Ama Uris

Training **Contents**

Aligns with standard industry frameworks (such as ISO 27001 or NIST SP 800-53) and professional GRC (Governance, Risk, and Compliance) practices.
Explain the cybersecurity onboarding training that employees will take.
• Explain how often employees must complete additional cybersecurity training. Justify your response.
• Describe how you would inform employees about new cyberthreats

1. Onboarding Cybersecurity Training (System Access & IT Policies)

All organisation employees will receive cybersecurity essentials and awareness training as a part of the onboarding process.

2. Ongoing Security Training (Evolving Threats & Monthly Cadence)

3. Incident & Threat Communications (Direct Alerts & Team Briefings)

Sample-Ama Uris

Training Control Overview

- *cybersecurity essentials and awareness training and training specific to employees job.*
- *complete training during onboarding and at regular intervals during their employment.*
- What else that's inline with laws and regulations? And which law and regulations are those or are ISO 27001 and NIST SP 800-53 the most relevant/binding, and do they have the strictest regulations?\
- Potentially include what incentivising 'motivating goals' can align under the organisations security goals? To ensure trainign becomes culture
    - **Community- and team-building events** that bring employees together in non-work related events, challenges, activities and hobbies.
    - **Points-based system** for doing regular security check-ins/procedures that provide points that can lead to a meaningful prize that adds monthly winners to a final winner list at the end of each quarter.
    - What else can create incentives in a non-hierrachial, generous and cost-effective way (preferably something sentimental that doesn't need a budget).

Sample-Ama Uris

Job Rotation **Contents**

Aligns with global frameworks (like NIST and ISO 27001) that emphasize Segregation of Duties (SoD) and the mitigation of "insider threats."

1. Cross-Training Framework (Operational Continuity)

2. Shared Accountability & Fraud Prevention (The 5-Person Rule)

3. Access Control Transitions & Role Swapping (Confidential Data Management)

Sample-Ama Uris

Job Rotation Control Overview

- Cross-training employees
    - Internal certification system:
        - 1. our communications and marketing department popularises and validates it as a recognised industry standard certification.
        - 2. Helps internal hiring process and promotions
-

Sample-Ama Uris

Mandatory Vacation **Contents**

Aligns with the regulatory frameworks SOX (Sarbanes-Oxley) and PCI DSS (Payment Card Industry Data Security Standard) that explicitly require the mitigation of fraud that ensures the identification of potential fraud, risk isolation, and documentation.

1. Purpose & Fraud Detection Mechanism

2. Out-of-Office Transition & Coverage Controls

3. Policy Justification (Auditing Cross-Training Effectiveness)

Sample-Ama Uris

Mandatory Vacation Control Overview

- Regular audits take place during vacation times (alongside random spot-check audits)
- Works in tandem with cross-training schedules
- How best do we implement this control? What are the best, safest, and most effective practices?

Sample-Ama Uris

Disaster Recovery Plan **Contents**

Aligns with global frameworks (such as ISO 22301 and NIST SP 800-34) that emphasize organizational resilience, service availability, and business continuity.

1. Control Overview ..... Page 26

- *Control Objective: Service Availability and Data Recovery*
- *Applicable Standards (e.g., ISO 22301, SOC 2, NIST)*
- *Risk Assessment: Business Impact Analysis (BIA)*

2. Roles and Responsibilities ..... Page 27

- *Disaster Recovery (DR) Coordinator*
- *Crisis Management Team*
- *Vendor and Third-Party Liaison*

3. Disaster Recovery Requirements ..... Page 28

- *Recovery Time Objectives (RTO) and Recovery Point Objectives (RPO)*
- *Critical Asset Identification*
- *Backup and Redundancy Strategy*

4. Procedural Implementation ..... Page 29

- *Plan Activation and Communication Triggers*
- *Step-by-Step Restoration Procedures*
- *Emergency Contact and Escalation Matrix*

5. Monitoring and Metrics ..... Page 30

- *Key Performance Indicators (KPIs) (e.g., Mean Time to Recovery)*
- *Test Drills and Simulation Results*

6. Continual Improvement ..... Page 31

- *Post-Incident Review (Lessons Learned)*
- *Periodic Plan Updates and Infrastructure Audits*

Sample-Ama Uris

7. Appendices / Evidence Artifacts ..... Page 32

- *Disaster Recovery Test Reports*
- *Off-site Backup Verification Logs*

Sample-Ama Uris

Disaster Recovery Control Overview

- A written Disaster Recovery plan for recovering data or systems if a disaster occurs (give alternatives specific to natural, equipment or malicious disaster).
- **Disaster preparedness plan**,
    - Ensures that the organization takes *precautions to prevent or mitigate the harm* that disasters cause.
- Beyond a Disaster Recovery Plan, what else goes into disaster recovery efforts/policy/procedures according to industry regulations/standards

Sample-Ama Uris